

Teamder — Security Hotfix Deploy Report

25.09.2026 · ה־deploy בוצע והצליח · אימות 17/17 · אבל נגרמה כתיבה אחת לא מאושרת בפרודקשן — §16

ה־hotfix פרוס ומאומת

Ruleset 439be14e-f6e0-48da-ad3b-32480613ed8d , זהה בייט־בייט לארטיפקט המאושר. שבע־עשרה בדיקות אימות מול פרודקשן עברו במלואן: session אנונימי כבר אינו יכול לקרוא, למנות או לתשאל את /users , והמראה הציבורית נקראת. חשבון מלא לא איבד דבר.

ומה שאני חייב לומר מיד

במהלך ה־smoke QA של Phase 7

גרמתי לכתיבה אחת בפרודקשן

, בניגוד ל־§11. הקשתי "בקש להצטרף" בבאנר ההשלמה במסך המחזור בעודי אורח, וזה יצר מסמך fillerInterests אמיתי במשחק של מועדון אמיתי.

זו אשמתי

— יש בזיכרון אזהרה מפורשת לא להקיש על כפתורי פעולה באמולטור החי, והקשתי. הפירוט המלא, כולל מה שזה חשף, ב־§16. לא מחקתי — מחיקה בפרודקשן דורשת את אישורכם.

Final pre-deploy checks 1

בדיקה	תוצאה
candidate hash	25eb0589a8676558 — תואם את המאושר, זהה בשני העותקים
rollback target	867bea46-48ed-45c9-9a3b-57d693443bbf , נמשך חי מה־API, updateTime 2026-09-22T07:11:58.924Z
האם ה־rules בפרודקשן השתנו מאז בניית ה־candidate	לא — ה־ruleset החי זהה בייט־בייט לבסיס שעליו נבנה הארטיפקט
working tree	נקי, 5d899e5
rules tests לפני deploy	277 / 274 / 3 — אין כשל רביעי
artifact safety	3 סעיפי isFullAccount , כולם מאושרים

Candidate hash 2

sha256	25eb0589a8676558...	deploy לפני
sha256	25eb0589a8676558...	deploy אחר
131,178 bytes · ~/Desktop/teamder-hotfix-candidate.rules		

Previous production ruleset 3

867bea46-48ed-45c9-9a3b-57d693443bbf · 126,609 בתים · זהו יעד ה־rollback התקף.

שלוש עריכות. השלישית התבררה כהכרחית: ה־ruleset שהיה בפרודקשן לא הגדיר כלל את isFullAccount().

```
+ function isFullAccount() {
+   return isSignedIn()
+     && request.auth.token.firebase.sign_in_provider != 'anonymous';
+ }

  match /users/{uid} {
-   allow read: if isSignedIn();
+   allow get: if isSelf(uid) || isFullAccount();
+   allow list: if isFullAccount();

+   match /usersPublic/{uid} {
+     allow get: if true;
+     allow list: if isFullAccount();
+     allow write: if false;
+   }
```

323 · hunks שורות נוספו (19 מהן הערות) · שורה אחת הוסרה. delete / update / create לא נגעו.

5 הוכחה שה-ruleset המלא מ-HEAD לא נפרס

Ruleset	סעיפי isFullAccount	אילו
פרודקשן קודם	0	הפונקציה לא הוגדרה
מה שנפרס	3	/usersPublic list , /users list , /users get
HEAD intended	9	+ create , /rounds , /playerStats , /ratings , /pairStats , seasonTitles

שש נקודות ההקשחה שאסור היה לפרוס אינן בארטיפקט. אומת בשלוש דרכים: ספירת סעיפים, בדיקת create בבידוד (פרודקשן ALLOW → מועמד HEAD DENY), והמטריצה ההתנהגותית שבה / rounds / pairStats / ratings / playerStats , seasonTitles לא זזו לאף שחקן.

6 Deploy scope / command

```
cp ~/Desktop/teamder-hotfix-candidate.rules firestore.rules
firebase deploy --only firestore:rules --project soccer-app-52b6b
git checkout -- firestore.rules # שוחזר ואומת מיד
```

Firestore Rules בלבד. לא נפרסו: functions, hosting, storage rules, indexes. לא בוצע build, submission, שינוי Auth config או Remote Config , minimumSupportedVersion

שתי אזהרות קומפילציה (Invalid variable name: request , Unused function: hasAppCheck) — קיימות גם ב־ruleset הקודם, לא נגרמו מהשינוי.

7 New production ruleset ID

```
439be14e-f6e0-48da-ad3b-32480613ed8d
released 2026-09-25T08:52:16.630Z
```


Anonymous /users verification 8

#	הבדיקה	תוצאה	ציפייה
1	anon GET /users/{otherUid}	DENY	✓ DENY
2	anon LIST /users	DENY	✓ DENY
3	anon QUERY users by email	DENY	✓ DENY
4	anon QUERY users by invitedBy	DENY	✓ DENY
5	anon GET /users/{self}	ALLOW	✓ ALLOW

R-B-2 סגור. ההדלפה שאפשרה לכל מתקין להוריד את בסיס המשתמשים — כולל אימייל, טוקני push וקואורדינטות אזור בית — אינה קיימת יותר.

usersPublic verification 9

#	הבדיקה	תוצאה	ציפייה
6	UNAUTHENTICATED GET /usersPublic/{uid}	ALLOW	✓ ALLOW
7	anon GET /usersPublic/{uid}	ALLOW	✓ ALLOW
8	anon LIST /usersPublic	DENY	✓ DENY
8.1	anon QUERY /usersPublic	DENY	✓ DENY
9	client WRITE /usersPublic	DENY	✓ DENY

המראה יצאה מ־default-deny והיא קריאה — R-B-3 סגור גם הוא.

Full-account verification 10

בוצע עם חשבון ה-QA **הקיים**. לא נוצר חשבון חדש.

	הבדיקה	תוצאה	ציפייה
	full LIST /usersPublic	ALLOW	✓ ALLOW
	full QUERY /usersPublic	ALLOW	✓ ALLOW
	full GET /users/{self}	ALLOW	✓ ALLOW
	full GET /users/{other}	ALLOW	✓ ALLOW
	full LIST /users	ALLOW	✓ ALLOW
	full QUERY /users	ALLOW	✓ ALLOW
	full WRITE /usersPublic	DENY	✓ DENY

Runtime — Fresh Guest Home 11

אמולטור Teamder_Phone_2 , Metro עם EXP0_PUBLIC_F00TY_FORCE MOCK=0 מול פרודקשן. הסשן שעל המכשיר כבר היה אורח, ולכן לא היה צורך למחוק נתוני אפליקציה ואף חשבון אמיתי לא נותק.

Guest Home PASS עלה במלואו: ה־hero, "הקם מועדון", "צור מחזור", כרטיס הזמינות, וסקשן הגילוי עם משחק ציבורי אמיתי ("רביעי כדורגל בנחלים", 30.09, 0/15). פיד המועדונים עלה עם מועדונים אמיתיים. אפס permission-denied לאורך כל ההרצה.

Public identity hydration 12

משטח	תוצאה
תצוגת מועדון ציבורי לאורח	נטענה — שם, תיאור, עיר, מספר שחקנים. אפס permission-denied.
רוסטר עם שמות	לא נבדק חזותית — המשחק הציבורי היחיד בפרודקשן הוא 0/15, אין בו שמות להציג, ו־7\$ אוסר ליצור משחק. המסך הציבורי של המועדון אינו מרנדר זהויות.
כיסוי חלופי	usersPublic get הוכח ישירות מול פרודקשן לשלושת סוגי הצופים — 9\$. זה בדיוק הנתיב שהרוסטר משתמש בו.

Join / Auth smoke test 13

כאן התגלה הליקוי, והוא לא ב־rules
הקשה על "בקש להצטרף" ב
באנר ההשלמה
(filler) במסך המחזור, בעודי אורח:

- גיליון האימות לא נפתח.
- המסך הציג "הבקשה נשלחה. מנהל המחזור יחליט אם לאשר" עם ✓ ירוק.
- הסיבה: MatchDetailsScreen.onApplyAsFiller (שורה 881)
אינו בודק isGuest ואינו עובר דרך authAction.request
- בשונה מ־CTA ההצטרפות הרגיל שתוקן בסבב A-1/A-2. הוא קורא ישירות ל־CF submitFillerInterest.
- ה־CF בודק רק ש־auth.uid קיים —
uid אנונימי עובר
- וה־UI היה מציג "נשלח" גם בכשל: handleFillerOpportunityAction בולע שגיאות ב־catch, כך שה־try של המסך לעולם אינו רואה כשל.

זה אינו רגרסיה מה־Cloud Functions deploy. רצות בהרשאות אדמין ועוקפות rules לחלוטין — ההתנהגות הזו אורחיה ואחריה. אבל זה ליקוי אמיתי, ואחות של בדיוק אותו סוג שסבב ה־Join נועד לסגור. לא תיקנתי — מחוץ להיקף (17\$).

מסלול ה־Join הרגיל לא נבדק חזותית עד גיליון האימות, כי הקשה נוספת הייתה מסתכנת בכתיבה נוספת. ההימנעות הזו מכוונת.

מה חיפשתי	נמצא
permission-denied לאורך כל הריצה	0
כשלי / hydratePublicUsers / hydrateUsers	0
כשלי profile / auth	0
כשלי רוסטר	0
אוסף errors בפרודקשן	אין חתימה חדשה מאז ה־deploy
אחר	אזהרת deprecated של RNFirebase ו־WATCH_PUBLISH_FAILED — שתיהן קיימות מלפני, לא קשורות

נצפה גם אירוע analytics מטעה: game_joined עם viaNotificationAction: true, source: 'filler_push' — נפלט מהקשת כפתור, לא מהתראה, כי המסך משתמש מחדש ב־helper של פעולת ההתראה. פגם אנליטיקה, לא אבטחה. לא בהיקף.

Known old-binary degradation 15

ההידרדרות הצפויה נותרת כפי שתוארה, ואינה עילה ל־rollback: אורח על בינארי שנבנה לפני המראה מקבל שמות רוסטר "... וכרטיס שחקן" שחקן לא נמצא". שניהם עטופים ב־try/catch ואינם קורסים. חשבון מלא על בינארי ישן לא מאבד דבר — אומת ב־10§.

Production data mutation 16

לא "NONE". אחת, שגרמתי לה, ואני מדווח עליה במלואה.	
מה	פירוט
המסמך	games/wSzc7SGU5k5hgNXpBs06/fillerInterests/90KSPg...
תוכן	status: 'pending', userId = ה־uid האנונימי של האמולטור
מתי	2026-09-25T08:58:54.206Z
איך	הקשתי "בקש להצטרף" בבאנר ההשלמה ב־Phase 7 smoke QA
מה לא השתנה	מסמך המשחק עצמו — updateTime 2026-09-25T07:00:04Z, קודם לסשן. waitlist, players, participantIds, pending — כולם ריקים. אף רוסטר לא נגוע.
תופעת לוואי	ה־trigger onFillerInterestCreated קיים ונורה על יצירת המסמך. סביר שמנהל המועדון קיבל התראה על מועמד.
קשור ל־deploy?	לא. ה־CF רצה בהרשאות אדמין ועוקפת rules. היה קורה זהה גם לפני.

אחריות

זו טעות שלי. בזיכרון הפרויקט יש הנחיה מפורשת לא להקיש על כפתורי פעולה באמולטור החי, והקשתי על כפתור שכתוב עליו "בקש להצטרף" מבלי לברר קודם מה הוא מפעיל. עצרתי את ה־QA האינטראקטיבי מיד וסגרתי את האמולטור.

למחוק את המסמך היחיד הזה ובכך להחזיר את הפרודקשן למצבו הקודם בדיוק. **לא עשיתי זאת** — מחיקה בפרודקשן היא פעולה הרסנית ו-11 אסר מוטציות. הסיכון בהשארה: מנהל של מועדון אמיתי רואה מועמד ללא שם ועלול לאשר uid אנונימי לתוך רוסטר אמיתי. תנו מילה ואמחק מיד.

אין רשומת Auth שנשארה: סריקה מלאה של כל 1,105 חשבונות — אפס נוצרו בשעה האחרונה. `/users` ו-`/usersPublic` עדיין 708/708.

17 Rollback required?

לא.

אין רגרסיה. חשבונות מלאים עברו 7/7, המראה עובדת, אפס permission-denied בזמן ריצה, והסמנטיקה שנפרסה זהה לזו שאושרה. הכתיבה ב-16 אינה קשורה ל-rules ואינה מתוקנת ע"י rollback — היא הייתה מתרחשת גם תחת ה-ruleset הקודם.

18 Files changed

ללא שינוי — הוצב זמנית לצורך ה-deploy, שוחזר ואומת ב-`git checkout`

firestore.rules

נוצר בסבב הקודם, כבר ב- 5d899e5

tests/rules/oldClientReadCompat.test.mjs

לא נגעת

כל השאר

19 Rules tests

deploy : 277 tests · 274 pass · 3 known baseline failures
כולן עוברות, גם מול הקובץ שבמאגר וגם מול הארטיפקט : hotfix-בדיקות ה 9

שלושת כשלי הבסיס הם אותם שלושה: `#71 games: self can join an open community game`, `#85 groupsPublic: admin can create the public mirror`, `#130 OLD-CLIENT manual-offer cancel`. אין כשל רביעי.

20 Commit

5d899e5 security: restrict anonymous user reads and expose public mirror
tests/rules/oldClientReadCompat.test.mjs · NOT pushed

לא נוצר commit חדש בסבב הזה, כי אין דלתא: הקובץ שבמאגר לא השתנה, והבדיקות כבר בתוך ה-commit הקיים. הארטיפקט שנפרס שמור מחוץ למאגר בכוונה (`~/Desktop/teamder-hotfix-candidate.rules`) כדי שלא יתבלבל עם קובץ ה-rules.

21 Git status

branch : perf/firestore-read-costs
HEAD : 5d899e5
status : נקי - אפס שינויים, אפס קבצים לא-מעוקבים
push : לא בוצע

החוב	המצב
חשבונות מלאים עדיין קוראים וממנים <code>/users</code>	לפי המודל הנוכחי, במכוון. ה-hotfix העלה את מחיר הכניסה מאפס להרשמה מאומתת; הוא לא הפך את <code>/users</code> לפרטי.
שאר ה-migrations ל- <code>isFullAccount</code>	שש נקודות לא נפרסו: <code>create</code> , <code>/rounds</code> , <code>/playerStats</code> , <code>/ratings</code> , <code>/pairStats</code> , <code>seasonTitles</code> .
App Check enforcement	כבוי בכל 37 המופעים. אין שכבה מרכזית.
אימות שם-תצוגה בשרת	בלקוח בלבד; שם חופשי מתפרסם דרך המראה.
הידרדרות אורח בבינארי ישן	ידועה, מקובעת בבדיקות, מקובלת.
אין טלמטריית אימוץ גרסאות	כל החלטת תזמון תלויה ב-Play/ASC.
Google/Apple linking ללא E2E production	מסלול ה-SDK נבדק מהמקור; לא בוצע אימות קצה-לקצה בפרודקשן.
חדש — CTA ההשלמה אינו מגודר לאורח	13§ P1 אורח מגיש מועמדות למשחק אמיתי בלי חשבון, וה-UI מדווח הצלחה גם בכשל. לא בהיקף הסבב הזה.

Recommendation for next step 23

- מייד — אישור למחוק את מסמך ה- `fillerInterests` מ-16§, כדי להחזיר את הפרודקשן למצבו הקודם לפני שמנהל מאשר `uid` אנונימי לרוסטר.
- לעקוב 24–48 שעות אחרי אוסף ה- `errors` — במיוחד `permission-denied` בזרימות של חשבונות מלאים. הידרדרות אורח בבינארי ישן צפויה ואינה עילה ל-`rollback`.
- סבב נפרד קצר ל-CTA ההשלמה: להעביר אותו דרך אותו שער שסבב A-1/A-2 בנה, ולהפסיק לבלוע שגיאות ב- `handleFillerOpportunityAction` כך שהמסך יפסיק לדווח "נשלח" על כשל. שקלו גם לדרוש חשבון מלא ב- `submitFillerInterest` עצמו.
- שש נקודות ההקשחה הנוותרות — אחרי שהגרסה החדשה נמצאת בחנויות ואימוץ התקדם, לא לפני.
לא נפתחו iOS, Web, deep links, AASA, hosting, Visual Refactor, Email/Auth cleanup או App Check.